COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.3 · Analyzing Vulnerabilities

Mestre CyberSec · **Lesson 4.3 — Analyzing Vulnerabilities** (10:29) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: CVSS 0-10: baixo 0.1-3.9; médio 4-6.9; alto 7-8.9; CRÍTICO 9-10. CVE=catálogo mundial. Prioriza por CVSS+exposição: crítico na internet = ontem.

💡 Key Exam Highlights & Critical Concepts

- CVSS 9+ = crítico; 7+ = alto
- Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'CVSS score of 9.8'=Critical

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.3 — Analyzing Vulnerabilities)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Common Vulnerability Scoring System (CVSS)

An open framework that assigns a numerical severity score from 0.0 to 10.0 to software vulnerabilities; Security+ classifies 0.1–3.9 Low, 4.0–6.9 Medium, 7.0–8.9 High, and 9.0–10.0 Critical.

⚠ ***Exam Trap:*** *Gatilho: 'CVSS score of 9.8' = Critical. Não confunda CVSS (severidade) com CVE (identificador).*

• Common Vulnerabilities and Exposures (CVE)

A standardized worldwide catalog and identifier for publicly known cybersecurity vulnerabilities, using the format CVE-YYYY-NNNNN.

⚠ ***Exam Trap:*** *CVE identifica a vulnerabilidade, mas não informa gravidade; use CVSS para pontuar e priorizar.*

• National Vulnerability Database (NVD)

A U.S. government repository that enriches CVE records with CVSS scores, CWE classifications, and affected product data.

⚠ ***Exam Trap:*** *NVD é a base que adiciona análise e pontuação ao CVE; não é o mesmo que CVE.*

• Common Weakness Enumeration (CWE)

A catalog of common software weakness types, such as buffer overflow or SQL injection, that can lead to vulnerabilities.

⚠ ***Exam Trap:*** *CWE descreve a classe da fraqueza; CVE identifica uma instância específica dessa fraqueza.*

• Exploit Prediction Scoring System (EPSS)

A scoring system that estimates the probability a vulnerability will be exploited in the wild in the next 30 days.

⚠ ***Exam Trap:*** *Ajuda a priorizar além do CVSS: EPSS alto + exposição à internet = ação urgente.*

• CISA Known Exploited Vulnerabilities (KEV) Catalog

A CISA catalog of vulnerabilities confirmed to be actively exploited in the wild, with required remediation deadlines for U.S. federal agencies.

⚠ ***Exam Trap:*** *Se uma vulnerabilidade está no KEV, há exploração ativa; priorize acima de CVSS isolado.*

• Attack Surface (N/A)

The sum of all possible entry points and exposed assets an attacker can use to exploit a system or organization.

⚠️ ***Exam Trap:*** *Prioridade = CVSS + exposição: superfície voltada à internet com vulnerabilidade crítica deve ser corrigida imediatamente.*

- **False Positive (FP)**

A vulnerability scanner finding that incorrectly reports a vulnerability or issue that does not actually exist.

⚠️ ***Exam Trap:*** *Valide achados antes de remediar; falsos positivos consomem tempo e podem mascarar riscos reais.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security analyst reviews a vulnerability scan of a public e-commerce server. The report shows a CVSS score of 9.8, the CVE is listed in the CISA KEV catalog, and a public exploit is available. A separate internal payroll server has a CVSS score of 7.5 with no known exploit and is not internet-facing. Which finding should be remediated first?

A) The public e-commerce server vulnerability because it is critical, internet-facing, and known to be exploited

B) The internal payroll server vulnerability because any high-severity issue must be patched before critical issues

C) The public e-commerce server vulnerability only after confirming that the payroll issue is a false positive

D) The internal payroll server vulnerability because it processes sensitive payroll data and has a lower CVSS score

QUESTION 2 · EXAM SCENARIO

A vulnerability management team must decide which of several CVEs are most likely to be exploited by attackers in the next 30 days, even before patches are broadly deployed. Which data source should they consult?

A) CWE

B) NVD

C) EPSS

D) CVE

QUESTION 3 · EXAM SCENARIO

While correlating findings from three different vulnerability scanners, an analyst needs a consistent public identifier so that the same software flaw is tracked across tools and reports. Which standard should be used?

A) CVSS

B) CVE

C) CWE

D) EPSS

QUESTION 4 · EXAM SCENARIO

A vulnerability scan reports a CVSS base score of 5.3 on an internal application. According to the standard CVSS qualitative severity ratings, how should this vulnerability be categorized?

A) Low

B) High

C) Critical

D) Medium

QUESTION 5 · EXAM SCENARIO

A scanner reports that a web server is running an outdated version of a CMS with a critical vulnerability. The administrator checks the server and finds that the CMS was removed months ago and the related service is not installed. How should this finding be classified?

A) True positive

B) False negative

C) False positive

D) True negative

QUESTION 6 · EXAM SCENARIO

A development team wants to understand recurring software weakness patterns such as improper input validation and use-after-free, independent of any specific product or CVE. Which resource should they use?

A) CVE

B) CVSS

C) CISA KEV

D) CWE

QUESTION 7 · EXAM SCENARIO

A vulnerability manager sees that a CVE affecting the organization's VPN appliance has been added to the CISA KEV catalog. What does this listing most strongly indicate?

A) The vulnerability has a CVSS score of exactly 10.0

B) The vulnerability is known to be exploited in real-world attacks

C) The vulnerability is only a theoretical weakness with no active threat

D) The vulnerability affects only end-user workstations, not network devices

QUESTION 8 · EXAM SCENARIO

An organization has limited patch deployment capacity. Two vulnerabilities both have CVSS 9.0. One affects an internet-facing customer portal, has EPSS 0.92, and is in CISA KEV. The other affects an internal test server, has EPSS 0.02, and is not in KEV. Which remediation strategy is most appropriate?

A) Patch the internal test server first because test systems are easier to update and will reduce the total number of findings

B) Delay both patches until the next quarterly maintenance window because both have the same CVSS score

C) Patch the internet-facing portal first because it has high severity, high exploit probability, and known exploitation

D) Patch only the internal test server because internet-facing systems cannot be patched without downtime

QUESTION 9 · EXAM SCENARIO

An analyst is reviewing a CVE in the National Vulnerability Database (NVD). Which type of information should the analyst expect the NVD to provide?

A) A guaranteed exploit kit for the vulnerability

B) The internal asset inventory of the affected organization

C) A prediction of the exact date the vendor will release a patch

D) Standardized vulnerability metadata such as CVSS scores, CWE mapping, and references

QUESTION 10 · EXAM SCENARIO

After analyzing vulnerabilities across its DMZ, a security team finds many unnecessary services, open ports, and administrative interfaces exposed to the internet. Which action best reduces the attack surface?

A) Increase the minimum password length for all domain accounts

B) Disable or remove unnecessary services and close unused ports on DMZ hosts

C) Enable full packet capture on the internal network for forensic analysis

D) Schedule vulnerability scans to run more frequently during business hours

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — The public e-commerce server vulnerability because it is critical, internet-facing, and known to be exploited

Risk-based prioritization combines CVSS severity with exposure and exploit intelligence. A CVSS 9.8 on an internet-facing host that is in CISA KEV and has a public exploit presents immediate, likely exploitation risk, so it should be addressed first. The internal 7.5 issue is still important but is lower urgency without exposure or known exploitation.

Question 2: Option C — EPSS

EPSS (Exploit Prediction Scoring System) estimates the probability that a vulnerability will be exploited in the wild in the near term, typically the next 30 days. CWE classifies weakness types, NVD provides vulnerability metadata, and CVE provides unique identifiers.

Question 3: Option B — CVE

CVE (Common Vulnerabilities and Exposures) provides a unique, standardized identifier for a specific publicly known vulnerability. CVSS is a severity score, CWE classifies weakness types, and EPSS predicts exploitation likelihood.

Question 4: Option D — Medium

Under the CVSS qualitative rating scale, scores from 4.0 to 6.9 are Medium. Low is 0.1-3.9, High is 7.0-8.9, and Critical is 9.0-10.0.

Question 5: Option C — False positive

A false positive occurs when a scanner reports a vulnerability that does not actually exist on the target. Here, the affected component is not present, so the finding is incorrect. True positive means the vulnerability exists, false negative means an existing vulnerability was missed, and true negative means no vulnerability exists and none was reported.

Question 6: Option D — CWE

CWE (Common Weakness Enumeration) is a categorized list of software and hardware weakness types. It helps developers identify and prevent classes of flaws. CVE identifies specific vulnerabilities, CVSS scores severity, and CISA KEV lists known exploited vulnerabilities.

Question 7: Option B — The vulnerability is known to be exploited in real-world attacks

CISA's Known Exploited Vulnerabilities (KEV) catalog lists vulnerabilities that have evidence of being exploited in the wild. Inclusion is a strong signal to prioritize remediation, regardless of other scoring alone. It does not mean CVSS 10.0 or that it is theoretical.

Question 8: Option C — Patch the internet-facing portal first because it has high severity, high exploit probability, and known exploitation

CVSS alone does not capture exposure or exploitation likelihood. The internet-facing portal has critical severity plus high EPSS and KEV status, indicating immediate risk. The internal test server is lower priority despite the same CVSS base score.

Question 9: Option D — Standardized vulnerability metadata such as CVSS scores, CWE mapping, and references

NVD enriches CVE records with standardized metadata including CVSS severity, CWE weakness mapping, references, and affected product information. It does not provide exploit kits, organizational asset inventories, or guaranteed patch dates.

Question 10: Option B — Disable or remove unnecessary services and close unused ports on DMZ hosts

Attack surface reduction removes or restricts exploitable entry points. Disabling unnecessary services and closing unused ports directly reduces the number of ways an attacker can reach or compromise DMZ systems. Password length, packet capture, and scan frequency can improve security but do not directly reduce exposed services and ports.